

GRC102: INFORMATION SECURITY GOVERNANCE

ASSIGNMENT 1

Principles of Information Security Governance

Student Name: Faith Mathapelo Letsoara

Registration number: C11/26/CGRC/17582

Cohort /Batch: Cohort 11

Instructor Name: Phezulu Dhlodhlo and Ene Rita Otal

Date of Submission: 11/09/2026

Part 1 - Governance Structure Analysis

1.1 Weaknesses in TechCorp's Current Information Security Governance

Weakness 1: Security Decision-Making Is Concentrated in One Individual

Governance Issue-Currently, the IT Director is responsible for most security decisions. This creates a single point of failure and limits independent oversight.

Business Impact-Important security decisions may be delayed or influenced by operational priorities instead of business risks. If the IT Director leaves the company, valuable knowledge and leadership could be lost.

Impact on International Expansion-As TechCorp expands internationally, security decisions will become more complex due to different legal and regulatory requirements. One person will not be able to effectively manage all governance responsibilities across multiple regions.

Weakness 2: Lack of Formal Security Governance Committees

Governance Issue-The organisation has no security committee or governance body responsible for overseeing cyber risk and information security strategy.

Business Impact-Without proper governance structures, security initiatives may not align with business objectives, and risks may go unnoticed until they become major incidents.

Impact on International Expansion-Expanding internationally increases exposure to cyber threats, privacy regulations, and operational risks. Without a governance committee, it will be difficult to coordinate security efforts across different countries.

Weakness 3: Limited Board Oversight

Governance Issue-The Board receives only one brief security update each year.

Business Impact-The Board cannot make informed decisions about cyber risks when it receives limited information. Serious risks may not receive adequate funding or attention.

Impact on International Expansion-International growth introduces new risks such as data protection laws, third-party vendor risks, and geopolitical threats. Limited Board oversight may result in poor strategic decisions regarding these risks.

Weakness 4: Outdated and Inconsistently Applied Security Policies

Governance Issue-Security policies exist but are outdated and not consistently enforced throughout the company.

Business Impact-Employees may follow different security practices, increasing the likelihood of security incidents, compliance failures, and operational disruptions.

Impact on International Expansion-Different countries have different regulatory requirements. Outdated policies may fail to meet international standards, potentially resulting in fines or legal consequences.

Weakness 5: Reactive Incident Management

Governance Issue-Security incidents are handled only after problems occur, with no formal governance, escalation, or response procedures.

Business Impact-Response times may be slow and responsibilities unclear, leading to increased financial losses and reputational damage.

Impact on International Expansion-As the company grows, incidents may affect customers and operations across multiple countries. Without a structured incident management process, the impact of cyberattacks could become significantly larger.

2 Proposed Information Security Governance Structure

Governance Organisational Chart



Key Governance Bodies and Their Responsibilities

Board Risk and Security Committee

Mandate:

- Provide strategic oversight of cybersecurity risks.
- Review security performance and risk reports.
- Approve major security investments.
- Ensure alignment between security and business objectives.

Information Security Governance Committee

Members

- CISO
- CIO
- Legal Representative
- Compliance Manager
- HR Representative
- Business Unit Leaders

Mandate

- Review security risks.
- Monitor compliance.
- Evaluate security programmes.
- Prioritise security initiatives.

Incident Response Steering Group

Mandate

- Manage major security incidents.
- Coordinate communication and escalation activities.
- Conduct lessons-learned reviews following incidents.

Defined Responsibilities

Board of Directors

- Establish governance expectations.
- Approve risk appetite.
- Review security performance.

CEO

- Ensure security is integrated into business strategy.
- Support security initiatives financially and operationally.

CISO

- Lead cybersecurity strategy.
- Report security risks to executive leadership and the Board.
- Ensure implementation of governance processes.

Business Unit Leaders

- Own risk within their departments.
- Enforce security policies and procedures.

Employees

- Comply with security policies.
- Report security incidents and suspicious activities.

Decision-Making, Escalation and Oversight Processes

Decision-Making

- Operational security decisions are made by security managers.
- Strategic decisions are approved by the Information Security Governance Committee.
- Enterprise-level risks are escalated to the Board Risk and Security Committee.

Escalation Process

Low Risk Incidents → Security Operations Team

Medium Risk Incidents → CISO and Governance Committee

High Risk Incidents → Executive Management and Board Committee

Oversight Process

- Monthly security reviews by the Governance Committee.
- Quarterly risk reporting to executives.
- Quarterly Board cybersecurity updates.
- Annual independent security audit.

Recommended Board Involvement

The Board should move from receiving annual updates to receiving quarterly cybersecurity reports.

These reports should include:

- Key cyber risks.
- Security incidents and trends.
- Compliance status.
- Risk treatment progress.
- Security investment requirements.
- International regulatory readiness.

Board members should also receive periodic cybersecurity awareness training to improve governance effectiveness.

3 Alignment with Core Governance Principles

Principle 1: Accountability

The proposed structure assigns clear responsibility to the Board, CEO, CISO, managers, and employees. This reduces confusion and ensures accountability for security outcomes.

Principle 2: Strategic Alignment

Security governance is aligned with business objectives by involving executive leadership and ensuring cybersecurity supports international expansion goals.

Principle 3: Risk Management

Regular risk reviews, escalation processes, and Board oversight ensure risks are identified, assessed, and managed proactively rather than reactively.

Principle 4: Performance Measurement

Quarterly reporting, audits, and governance reviews provide measurable indicators of security effectiveness and support continuous improvement.

Part 2 - Framework Comparison and Selection

4. Comparison of COBIT and ISO/IEC 27001

Criteria	COBIT	ISO/IEC 27001
Primary Focus	Enterprise governance and management of information and technology.	Establishing, implementing, maintaining, and improving an Information Security Management System (ISMS).
Scope	Broad organisational governance covering IT strategy, performance, risk, value delivery, and compliance.	Focused specifically on information security management and protection of information assets.
Governance Approach	Strong emphasis on governance, leadership, accountability, and business alignment.	Focuses on managing information security risks through a structured management system.
Structure	Consists of governance objectives, management objectives, processes, practices, and performance metrics	Based on clauses and Annex A security controls supported by risk assessments.
Risk Management	Enterprise-wide technology and business risk management.	Information security risk identification, treatment, and monitoring.
Control Selection	Provides governance objectives but does not prescribe detailed security controls.	Offers a comprehensive set of security controls through Annex A.
Certification	Organisations cannot be certified against COBIT.	Organisations can achieve ISO 27001 certification through accredited audits.
Regulatory Alignment	Supports regulatory compliance through governance and control management.	Strong alignment with regulatory frameworks and compliance requirements, including healthcare regulations
HIPAA Support	Helps establish governance structures supporting HIPAA compliance.	Supports HIPAA compliance through risk management, access control, monitoring, and security controls.

Resource Requirements	Requires executive involvement, governance committees, and business participation.	Requires dedicated security resources, documentation, audits, and continuous improvement activities.
Strengths	Strong governance, strategic alignment, accountability, and performance measurement.	Internationally recognised standard with clear security requirements and certification capability.
Limitations	Less detailed from a security control perspective.	Less comprehensive in enterprise governance and board-level oversight.

5. Recommendation for MedSecure

I recommend that MedSecure adopt both COBIT and ISO/IEC 27001 in a complementary manner, with ISO/IEC 27001 serving as the primary security framework and COBIT providing governance oversight.

Healthcare Sector Requirements

Healthcare organisations manage highly sensitive patient information, making confidentiality, integrity, and availability critical business requirements. ISO 27001 provides a structured approach for protecting this information through risk assessments, security controls, policies, and continuous improvement.

At the same time, healthcare organisations require strong executive oversight to ensure security investments align with organisational objectives. COBIT supports this requirement by providing governance mechanisms that connect cybersecurity activities with business goals.

MedSecure's Size and Complexity

With approximately 2,000 employees operating across three states, MedSecure is large enough to require both operational security management and strategic governance.

ISO 27001 would help standardise security practices across all locations, while COBIT would provide management with visibility into security performance, risk exposure, and compliance activities.

Together, the frameworks support consistency across the organisation while maintaining accountability at executive and board levels.

Ability to Support HIPAA Compliance

HIPAA requires healthcare organisations to implement administrative, physical, and technical safeguards to protect patient information.

ISO 27001 aligns well with these requirements through:

- Access management controls
- Risk assessments
- Security monitoring
- Incident management
- Business continuity planning
- Policy management

COBIT complements these activities by ensuring governance oversight, performance monitoring, and accountability for compliance efforts.

While neither framework guarantees HIPAA compliance on its own, both significantly support MedSecure's compliance objectives.

Implementation Challenges

The organisation may face several challenges, including:

- Employee resistance to new processes
- Resource constraints
- Documentation requirements
- Staff training needs
- Integration with existing systems

To mitigate these challenges, implementation should occur gradually through clearly defined phases and supported by executive sponsorship.

Long-Term Sustainability

A combined framework approach offers long-term value.

ISO 27001 promotes continuous improvement through regular reviews and audits, while COBIT ensures governance practices evolve alongside business growth and regulatory changes.

As MedSecure expands, this combination provides flexibility without sacrificing governance effectiveness.

6. High-Level Implementation Roadmap

Phase 1: Assessment and Planning

Activities

- Conduct current-state assessment
- Perform gap analysis
- Identify HIPAA compliance gaps

- Define governance structure
- Obtain executive support

Success Factors

- Strong executive sponsorship
- Stakeholder engagement
- Clear project objectives

Challenges

- Incomplete understanding of existing controls

Mitigation

- Use interviews, workshops, and documentation reviews

Phase 2: Governance Foundation (Months 3-4)

Activities

- Establish governance committees
- Define roles and responsibilities
- Approve security policies
- Develop risk management framework

Success Factors

- Clear accountability
- Board involvement

Challenges

- Unclear ownership of security risks

Mitigation

- Develop RACI matrix and governance charter

Phase 3: ISO 27001 ISMS Implementation (Months 5-10)

Activities

- Create ISMS
- Perform risk assessments
- Implement controls
- Develop procedures
- Conduct security awareness training

- **Success Factors**
- Management commitment
- Employee participation

Challenges

- Documentation workload

Mitigation

- Prioritise high-risk areas first

Phase 4: Monitoring and Internal Audit (Months 11-12)

Activities

- Conduct internal audits
- Measure performance metrics
- Review risk treatment plans
- Correct identified weaknesses

Success Factors

- Continuous monitoring

Challenges

- Identifying meaningful metrics

Mitigation

- Establish KPIs and reporting dashboards

Phase 5: Certification and Continuous Improvement (Months 13-15)

Activities

- Certification readiness assessment
- External ISO 27001 audit
- Management reviews
- Continuous improvement programme

Success Factors

- Well-maintained documentation
- Ongoing leadership support

Challenges

- Maintaining compliance momentum

Mitigation - Schedule regular governance reviews and security assessments

Resource Requirements

People

- CISO
- Compliance Officer
- IT Security Team
- Risk Manager
- Internal Audit Team
- External ISO Consultant (optional)

Technology

- Risk management tools
- Vulnerability management solutions
- Security monitoring platforms
- Policy management systems

Financial Resources

- Staff training
- Consulting support
- Audit and certification costs
- Security technology investments

Conclusion

In conclusion, for MedSecure, the most effective approach is to use ISO/IEC 27001 as the operational information security framework and COBIT as the governance framework. ISO 27001 provides the controls, processes, and certification capability needed to protect patient information and support HIPAA compliance, while COBIT provides executive oversight, accountability, and alignment between security initiatives and business objectives. This combined approach creates a sustainable governance model capable of supporting MedSecure's current needs and future growth.

Part 3 - Case Study Analysis: Equifax Data Breach

Governance Failures That Contributed to the Equifax Breach

7. Governance Failure 1: Poor Vulnerability Management Oversight

Governance Issue-Equifax was notified about the Apache Struts vulnerability in March 2017, but the affected systems were not patched successfully.

Contribution to the Breach-The unpatched vulnerability provided attackers with a path into the environment, ultimately leading to unauthorized access to sensitive customer data.

Governance Principle Not Applied-Risk management and accountability were not effectively implemented. Effective governance requires critical vulnerabilities to be tracked, monitored, and verified until remediation is complete.

Governance Failure 2: Lack of Clear Accountability

Governance Issue-Investigations following the breach highlighted unclear ownership of cybersecurity responsibilities.

Contribution to the Breach-Without clearly assigned responsibilities, critical security tasks such as patch management, monitoring, and risk reporting were not effectively managed.

Governance Principle Not Applied-Accountability. Effective governance requires clearly defined ownership of security risks and control activities.

Governance Failure 3: Inadequate Board Oversight

Governance Issue-The Board did not exercise sufficient oversight regarding cybersecurity risks.

Contribution to the Breach-Cybersecurity risks may not have received sufficient strategic attention, funding, or monitoring from senior leadership.

Governance Principle Not Applied-Leadership and oversight. Boards are responsible for ensuring cyber risks are managed appropriately and aligned with organisational objectives.

Governance Failure 4: Poor Network Segmentation

Governance Issue-The organisation failed to adequately separate critical systems and sensitive data environments.

Contribution to the Breach-Once attackers gained access, they were able to move through the network and access a much larger volume of sensitive information than would otherwise have been possible.

Governance Principle Not Applied-Defense-in-depth and risk reduction. Good governance promotes layered security controls that limit the impact of a successful attack.

Governance Failure 5: Weak Monitoring and Control Management

Governance Issue-Investigators found that expired SSL certificates impaired visibility into network activity.

Contribution to the Breach-Security teams had reduced ability to identify suspicious activity, allowing attackers to remain undetected for an extended period.

Governance Principle Not Applied-Continuous monitoring and performance measurement. Governance requires organisations to continuously monitor the effectiveness of security controls.

Governance Failure 6: Delayed Incident Detection and Response

Governance Issue-The breach occurred between May and July but was only discovered on 29 July.

Contribution to the Breach-The delay increased the amount of information compromised and extended attacker access.

Governance Principle Not Applied-Incident management and operational resilience. Effective governance requires proactive detection and rapid response capabilities.

8. Governance Structures, Processes and Controls I Would Have Implemented as CISO

If I had been the CISO prior to the breach, my focus would have been establishing strong governance structures that promoted accountability, visibility, and proactive risk management.

Governance Bodies and Responsibilities

Board Cybersecurity and Risk Committee

Responsibilities:

- Review cyber risks quarterly.
- Approve cybersecurity strategy.
- Review significant security incidents.
- Monitor compliance and risk trends.

Security Governance Committee

Members:

- CISO
- CIO

- Legal Counsel
- Compliance Manager
- Security Managers
- Business Leaders

Responsibilities:

- Review security performance.
- Oversee risk management activities.
- Prioritise security investments.
- Monitor remediation activities.

Accountability Mechanisms

A formal RACI model would be implemented to define responsibility and ownership of key security activities.

Activity	Responsible	Accountable
Patch Management	Infrastructure Team	CIO
Vulnerability Management	Security Team	CISO
Incident Response	SOC Team	CISO
Risk Assessments	Risk Team	CISO
Policy Management	Governance Team	CISO

Risk Management Processes

I would establish an enterprise security risk management programme that includes:

- Regular risk assessments.
- Risk register maintenance.
- Risk prioritisation based on impact and likelihood.
- Executive review of high-risk findings.
- Board reporting of critical cyber risks.

This approach ensures that security risks are managed proactively rather than reactively.

Board Reporting and Oversight

The Board would receive quarterly reports covering:

- Critical vulnerabilities.
- Security incidents.
- Risk exposure levels.
- Compliance status.
- Remediation progress.
- Security maturity metrics.

This reporting would allow informed decision-making and improved oversight.

Policy Enforcement

The organisation would establish policies covering:

- Vulnerability management.
- Patch management.
- Incident response.
- Access control.
- Third-party security.

Compliance would be monitored through regular audits and control assessments.

Vulnerability Management Governance

A robust vulnerability management programme would include:

1. Asset inventory management.
2. Continuous vulnerability scanning.
3. Risk-based vulnerability prioritisation.
4. Defined remediation timelines.
5. Verification that patches have been successfully applied.
6. Executive escalation for unresolved critical vulnerabilities.

This would significantly reduce the likelihood of critical vulnerabilities remaining unpatched.

9. Wider Governance Lessons from the Equifax Breach

Increased Regulatory Expectations

The Equifax incident demonstrated that regulators expect organisations to treat cybersecurity as a business risk rather than a purely technical issue.

Organisations are now expected to demonstrate:

- Effective governance structures.
- Formal risk management programmes.
- Timely patch management.
- Strong incident response capabilities.
- Executive accountability.

Increased Board Involvement

The breach highlighted the importance of Board-level cyber oversight.

Today, many organisations:

- Establish dedicated cyber risk committees.
- Include cybersecurity expertise at Board level.
- Require regular cyber risk reporting.
- Integrate cyber risk into enterprise risk management programmes.

The role of the Board has evolved from passive awareness to active governance participation

Greater Executive Accountability

The resignations of the CIO and CSO demonstrated that executive leaders can be held accountable for governance failures.

Modern CISOs are expected to:

- Communicate risks clearly.
- Ensure remediation activities are completed.
- Report governance failures promptly.
- Support business decision-making with risk-based information.

Cybersecurity is now considered an executive leadership responsibility rather than solely an IT issue.

Lessons for Similar Organisations

Organisations that manage large volumes of sensitive information should learn several key lessons from Equifax:

1. Vulnerability management must be continuously monitored.
2. Critical patches should be verified after deployment.
3. Board oversight should be regular and meaningful.
4. Security responsibilities must be clearly assigned.
5. Network segmentation should limit attacker movement.
6. Security monitoring tools must be maintained and regularly tested.
7. Cybersecurity governance should be integrated into enterprise risk management.

Conclusion

The Equifax breach was not simply the result of a technical vulnerability. It was ultimately a failure of information security governance. Weak accountability, insufficient Board oversight, poor vulnerability management, inadequate monitoring, and ineffective risk management allowed a preventable vulnerability to develop into one of the largest data breaches in history. Strong governance structures, clear accountability, proactive risk management, and active executive oversight could have significantly reduced both the likelihood and impact of the incident.

Part 4 - Governance Principles Application

10. Information Security Governance Principles for GlobalFinance

As a multinational financial services organisation operating across 20 countries, GlobalFinance requires governance principles that ensure consistent protection of information assets while accommodating regional legal and operational requirements.

Principle 1: Security Is a Business Responsibility

Importance

Information security should not be viewed solely as an IT function. Every employee, manager, and executive has a role in protecting organisational information.

Application in Practice

- Security responsibilities are included in job descriptions.
- Managers are accountable for security within their business units.
- Security awareness training is mandatory for all employees.

Implementation Challenges

Different regions may have varying levels of security maturity, making it difficult to achieve consistent accountability across the organisation.

Principle 2: Risk-Based Decision Making

Importance-Resources should be focused on addressing the most significant risks rather than attempting to treat all risks equally.

Application in Practice

- Conduct regular risk assessments.
- Maintain a global risk register.
- Prioritise investments based on business impact.

Implementation Challenges

Regions may assess risks differently, resulting in inconsistent prioritisation and treatment.

Principle 3: Compliance by Design

Importance-Financial institutions operate under strict regulatory requirements. Compliance should be integrated into business processes rather than added afterwards.

Application in Practice

- Regulatory requirements are incorporated into project planning.
- Compliance reviews occur throughout system lifecycles.
- Security controls are mapped to relevant regulations.

Implementation Challenges

Different countries may have conflicting regulatory requirements that require careful coordination.

Principle 4: Least Privilege and Access Control

Importance-Employees should have access only to the systems and information necessary to perform their roles.

Application in Practice

- Role-based access control (RBAC).
- Privileged access management solutions.
- Regular access reviews.

Implementation Challenges

Business units often request broader access rights to improve productivity, creating resistance to restrictions.

Principle 5: Transparency and Accountability

Importance-Clear reporting and accountability promote trust and ensure that security issues are addressed promptly.

Application in Practice

- Defined ownership for risks and controls.
- Executive security reporting.
- Performance metrics and dashboards.

Implementation Challenges

Multiple reporting structures across regions can complicate accountability.

Principle 6: Continuous Monitoring and Improvement

Importance-Cyber threats evolve continuously, requiring organisations to adapt and improve security controls regularly.

Application in Practice

- Security monitoring programmes.
- Vulnerability assessments.
- Internal audits and maturity reviews.

Implementation Challenges

Monitoring capabilities may vary between regions, leading to inconsistent visibility.

Principle 7: Security by Design

Importance-Security should be incorporated into systems and processes from the beginning rather than added after implementation.

Application in Practice

- Security reviews during project planning.
- Secure software development practices.
- Architecture risk assessments.

Implementation Challenges

Project teams may perceive security reviews as delaying project delivery.

Principle 8: Incident Preparedness and Resilience

Importance-No organisation can eliminate all cyber risks. Therefore, the ability to detect, respond to, and recover from incidents is critical.

Application in Practice

- Incident response plans.
- Business continuity planning.
- Disaster recovery testing.

Implementation Challenges

Coordinating response activities across multiple countries and time zones.

Principle 9: Third-Party Risk Management

Importance-Financial institutions depend heavily on vendors, cloud providers, and business partners.

Application in Practice

- Vendor security assessments.
- Contractual security requirements.
- Continuous vendor monitoring.

Implementation Challenges

Different regional procurement processes may make standardisation difficult.

11. Balancing Competing Organisational Needs

Global Consistency vs Local Flexibility

GlobalFinance should establish a common set of mandatory security standards that apply worldwide. However, regional offices should have flexibility to implement additional controls to address local regulatory, cultural, or operational requirements.

For example, all regions must follow corporate access control standards, while individual countries may introduce additional privacy controls to satisfy local laws.

Security Requirements vs Business Agility

Effective governance must protect information without creating unnecessary obstacles for the business.

This balance can be achieved by:

- Applying risk-based approvals.
- Automating security processes.
- Embedding security into project lifecycles.
- Using security champions within business units.

This approach enables innovation while maintaining appropriate risk management.

Compliance Obligations vs Innovation

Compliance should support innovation rather than restrict it.

By involving security and compliance teams early in projects, potential regulatory issues can be identified and addressed before they become barriers to implementation.

This allows GlobalFinance to introduce new technologies while maintaining regulatory compliance.

Centralised Oversight vs Distributed Responsibility

The central security function should define governance principles, policies, and minimum standards.

Regional leaders should be responsible for implementing these requirements and managing local risks.

This model promotes consistency while ensuring accountability remains close to operational activities.

Governance Mechanism for Maintaining Adherence

Measuring and Reporting Adherence

GlobalFinance should establish Key Performance Indicators (KPIs) and Key Risk Indicators (KRIs) to monitor adherence. Regional reports should be submitted monthly, with consolidated reporting provided to executive management and the Board quarterly.

Accountability Across Organisational Levels

Board of Directors

- Approve governance principles.
- Review enterprise cyber risk reports.
- Monitor security performance.

Global CISO

- Own governance programme.
- Monitor organisation-wide compliance.
- Report risks to executives and the Board.

Regional Leadership

- Implement governance principles locally.
- Manage regional risks.
- Ensure compliance with requirements.

Employees

- Follow policies and procedures.
- Report incidents and suspicious activities.
- Participate in mandatory training programmes.

Managing Exceptions and Conflicts

A formal exception management process should be established.

The process should require:

1. Documentation of the exception request.
2. Risk assessment of the proposed exception.
3. Approval by appropriate governance authorities.
4. Defined expiry dates.
5. Regular review of exceptions.

This ensures deviations from policy are controlled and properly justified.

Continuous Review and Improvement

Governance principles should not remain static. They should be reviewed annually or following significant events such as:

- Major security incidents.
- Regulatory changes.
- Business acquisitions.
- Technology transformation initiatives.

Lessons learned from audits, incidents, and risk assessments should be used to improve governance processes

Conclusion

The proposed governance principles provide GlobalFinance with a practical framework for managing information security across a large multinational environment. By promoting accountability, risk-based decision-making, continuous improvement, and strong oversight, the organisation can maintain global consistency while allowing regional flexibility. Effective governance will enable GlobalFinance to meet regulatory obligations, support innovation, and strengthen resilience against evolving cyber threats.

References

- COBIT. (2019). *COBIT 2019 framework: Introduction and methodology*. ISACA.
- Equifax Inc. (2017, September 7). *Equifax announces cybersecurity incident involving consumer information*. <https://investor.equifax.com>
- ISACA. (2019). *COBIT 2019 framework: Governance and management objectives*. ISACA.
- International Organization for Standardization. (2022). *ISO/IEC 27001:2022 information security, cybersecurity and privacy protection: Information security management systems requirements*. ISO.
- U.S. Department of Health & Human Services. (2025). *Health Insurance Portability and Accountability Act (HIPAA)*. <https://www.hhs.gov/hipaa>
- U.S. Federal Trade Commission. (2019). *Equifax data breach settlement*. <https://www.ftc.gov>
- Von Solms, R., & Von Solms, B. (2020). *Information security governance*. Springer.
- Whitman, M. E., & Mattord, H. J. (2022). *Principles of information security* (7th ed.). Cengage Learning.